



# Technology Governance Program Guide

---

**Health Insurance Portability and Accountability Act (HIPAA)**

A complete overview of the Centience governance model built for HIPAA-regulated organizations.

## 1. The HIPAA Governance Imperative

HIPAA Security Rule is fundamentally a governance framework. It requires a process for managing ePHI security risk continuously:

- The Security Risk Analysis (164.308(a)(1)) is a required ongoing process. The governance program converts the SRA from an annual project into a continuous operational function.
- HIPAA requires implementation of policies, procedures, and controls and evidence that they work. The program produces that evidence automatically through managed infrastructure and continuous monitoring.
- OCR enforcement actions consistently target organizations with governance failures: outdated risk analyses, policies that do not reflect actual operations, missing BAAs, and untested contingency plans.
- The Centience model connects HIPAA policy obligations to technical enforcement through managed infrastructure so audit logs, access controls, and encryption are enforced and evidenced continuously.

## 2. Phase 1 — HIPAA Governance Assessment

The assessment establishes your current governance posture against HIPAA Security Rule requirements. Scope includes:

- Security Risk Analysis: Current risk analysis reviewed for completeness with all ePHI environments covered, threats and vulnerabilities identified, risk ratings documented, and remediation plan in place.
- Technical Safeguards Audit: Encryption status on all ePHI systems and devices, access controls and audit logging configuration, unique user identification compliance, and transmission security.
- Physical Safeguards Review: Facility access controls for systems containing ePHI, workstation security, and device and media control procedures.
- Business Associate Review: Inventory of all BAs with executed BAAs and BAA terms reviewed for compliance with 2013 Omnibus Rule requirements.
- Deliverable: Prioritized risk register with HIPAA rule citation, OCR enforcement context, risk rating, and remediation guidance.

## 3. Phase 2 — HIPAA Governance Roadmap

The roadmap sequences remediation against HIPAA enforcement risk and OCR investigation patterns:

- Critical within 30 days: Active Security Rule violations including unencrypted portable devices with ePHI, missing BAAs with active vendors, and no documented risk analysis.
- High within 90 days: Likely OCR findings including outdated risk analysis, shared accounts on ePHI systems, no contingency plan, and missing workforce training records.
- Medium within 180 days: Indirect enforcement exposure including incomplete audit log coverage, addressable safeguards not implemented or documented, and access review gaps.
- Roadmap integrates HIPAA policy updates alongside technical remediation so Privacy and Security policies are updated to reflect actual controls as they are implemented.

## 4. Phase 3 — HIPAA Ongoing Governance Program

The program phase converts remediation into continuous HIPAA governance. Cadence aligned to OCR audit expectations:

- Monthly: ePHI access log review, patch status for clinical and healthcare systems, backup verification for ePHI systems, and security incident log review.
- Quarterly: Access review for ePHI systems, BA inventory review and BAA status confirmation, workforce training completion tracking, and governance dashboard for Privacy Officer.
- Annually: Full Security Risk Analysis refresh, HIPAA policy review and update cycle, contingency plan test with documented results, BA due diligence refresh, and OCR enforcement action review and gap assessment.
- Breach Response: Defined breach response procedures with 60-day notification timeline built into the program. Four-factor low probability analysis template maintained and ready.

## 5. HIPAA Regulatory Change Management

HIPAA rulemaking, HHS guidance, and OCR enforcement patterns evolve continuously. The governance program includes proactive healthcare regulatory monitoring:

- Monitoring: HHS Federal Register rulemaking, OCR enforcement actions and resolution agreements, HHS guidance documents, and state healthcare privacy law changes.
- Impact Assessment: Each regulatory change assessed for policy update requirements, technical control implications, and BA contract requirements within 30 days of publication.
- Centience clients receive proactive notice of HIPAA rulemaking with implementation timelines, OCR enforcement trends relevant to their organization type, and state law changes in their operating jurisdictions.

## 6. HIPAA Governance Program Readiness Checklist

A mature HIPAA governance program should be able to demonstrate:

- Current Security Risk Analysis covering all ePHI environments updated within prior 12 months or after material change
- Risk management plan with documented remediation status for all identified risks
- HIPAA Privacy and Security policies current, signed, and reflecting actual operations
- BAA inventory complete with executed BAAs for all BAs with active ePHI access
- Workforce training records current with annual training completion and dates and content documented
- Contingency plan tested within prior 12 months with backup restore test and DR test results on file
- Incident and breach log current with all security incidents documented with disposition
- Audit log coverage confirmed for all ePHI systems with 6-year retention

## NEXT STEP

# Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

## WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

**Book Your Assessment →**

[centience.ai/assessments/healthcare](https://centience.ai/assessments/healthcare)

Call us: (877) 945-7177